

BEFORE Placeholder

AFTER

Integration Pattern: SSO & Access (Default for SaaS)

Document classification: Internal

Pattern owner: Security Engineering/Architecture

Version: 0.1

Approved for use with tiers: Critical / Important / Low (default)

Last review: _____

1. Purpose

This pattern defines the default approach for third-party SaaS access using Single Sign-On (SSO) and role-based access control (RBAC) to enforce least privilege, reduce credential risk, and improve auditability.

2. Default position

- SSO is the default for user access where the supplier supports SAML/OIDC.
- Local user accounts are avoided except where the service cannot support SSO for specific roles or use cases.
- Administrative access is tightly controlled, monitored, and periodically reviewed.

3. When to use

Use this pattern when:

- users will access a supplier SaaS via web or client application, and/or
- supplier provides an admin console/tenant for configuration, and/or
- supplier offers SSO/RBAC features.

4. Minimum requirements (baseline)

4.1 Authentication

MUST:

- Use SSO (SAML/OIDC) for standard user access where supported.
- Enforce MFA for administrative access (and for all users where the identity provider policy requires it).
- Prohibit shared accounts for normal usage.

SHOULD:

- Enforce conditional access (device compliance, geo restrictions) for Critical suppliers where feasible.
- Require step-up authentication for sensitive actions where supported.

4.2 Authorisation (RBAC / least privilege)

MUST:

- Implement RBAC with least privilege roles aligned to job function.
- Restrict the number of global/tenant admins; assign admin rights only to named users.
- Use separate roles for:
 - daily operations vs administration
 - read-only vs change privileges (where applicable)

SHOULD:

- Create tiered admin roles (e.g., admin vs security admin vs billing admin) if supported.
- Use separate admin accounts only where required by the platform (and document the reason).

4.3 Provisioning and deprovisioning

MUST:

- Define joiner/mover/leaver process for granting and removing access.

- Remove access promptly when a user leaves or changes role.
- Ensure supplier access is removed during supplier offboarding.

SHOULD:

- Use automated provisioning (e.g., SCIM) where supported.
- Maintain access groups mapped to roles (group-driven access) to reduce manual errors.

4.4 Break-glass / emergency access

MUST (Critical/Important suppliers):

- Maintain a documented break-glass approach if required by the supplier:
 - controlled storage of credentials
 - limited holders
 - MFA where supported
 - approvals and post-use review
- Break-glass accounts must not be used for day-to-day administration.

SHOULD:

- Implement alerting for any break-glass use.

4.5 Logging and auditability

MUST:

- Enable audit logging for:
 - authentication events (SSO logins, failures) where available
 - administrative actions (role changes, configuration changes)
- Ensure logs are retrievable for investigations and audits.

SHOULD:

- Forward logs to central logging/SIEM where practical for Critical suppliers.

- Alert on high-risk events (new admin assignment, failed login bursts, suspicious geo, MFA disabled).

4.6 External sharing / collaboration controls (if supported)

MUST:

- Restrict external sharing or collaboration features to approved domains/users where applicable.
- Document and approve any public sharing features used.

SHOULD:

- Periodically review external sharing settings and access.

5. Implementation steps (high level)

1. Confirm supplier supports SAML/OIDC and define SSO ownership (IdP admin role).
2. Define role model (RBAC) and map roles to groups.
3. Configure SSO and enforce MFA/conditional access as required.
4. Restrict tenant admin roles and create minimal admin set.
5. Enable audit logs and define retention/retrieval.
6. Validate: test login flows, role enforcement, and deprovisioning.
7. Record evidence and sign off prior to broad rollout.

6. Validation checklist (sign-off)

Record evidence location for each item.

SSO: ☐ SSO configured and tested (SAML/OIDC)

☐ User access is group-driven (where possible)

☐ Local accounts disabled/not used for standard users (or documented exceptions)

MFA / conditional access: ☐ MFA enforced for admin access
☐ Conditional access applied for Critical suppliers (if applicable)

RBAC: ☐ Roles defined and least privilege confirmed
☐ Admin roles restricted to named users
☐ No shared accounts for standard usage

Provisioning: ☐ Joiner/mover/leaver process documented
☐ Deprovisioning tested (account removal/role removal)
☐ SCIM enabled (if supported) or manual process defined

Logging: ☐ Audit logging enabled for admin actions
☐ Authentication logs available/retrievable
☐ Log retention and retrieval method documented

Sign-off: Security Engineering/Architecture (role title): _____ Date: _____ IT/Platform
Owner (role title): _____ Date: _____ Business Service Owner (role title):
_____ Date: _____

7. Exceptions

If SSO cannot be implemented:

- document the technical constraint
- enforce MFA for all users (minimum)
- restrict access via allowlists/conditional controls where feasible
- raise an exception if this violates Tier requirements, with expiry and remediation plan